

NAME: Mary Nyambura Gitau

GMAIL:marynyambura657@gmail.com

ADMISSION NUMBER: CS-SA12-26067

VULNERABILITY ASSESSMENT WITH HACK THE BOX

1.1 Introduction

This module focuses on understanding how to perform vulnerability scanning and penetration testing effectively. It covers best practices for conducting scans and emphasizes the importance of following compliance standards throughout the process. We will be introduced to two widely used vulnerability scanning tools: Nessus and OpenVAS. The module will guide us on how to install both tools on our virtual machines, perform scans, apply best scanning practices, and export the results for further analysis. Additionally, we will learn how to write clear and professional reports based on the findings obtained from the scans.

1.2 Nessus Skill Assessment

Nessus is an essential tool for penetration testing, vulnerability management, and network security auditing. It was developed by Tenable, Inc.

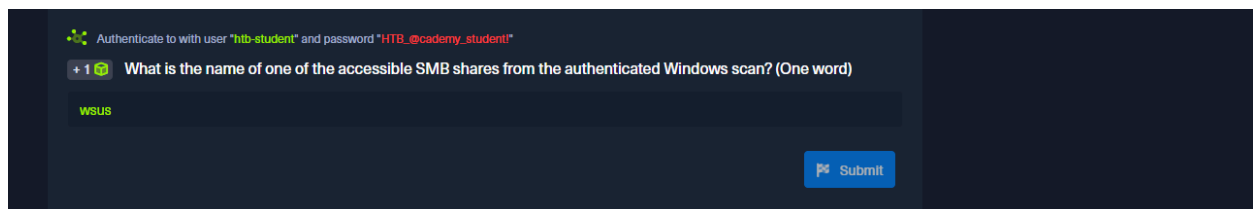
In this module I have clearly navigated how to install, sign in , scan vulnerability , identify ports, plugin ID and analyze vulnerability in general.

I was required to perform a basic network scan using nessus. I logged into the nessus site using the target ip provided -10.129.5.93:8834 in the mozilla Firefox. I logged in with credentials provided also. I named my project **windows_assignment**. After filling all the required information as requested , I launched and it took 60 mins for the scan to be complete.

Question

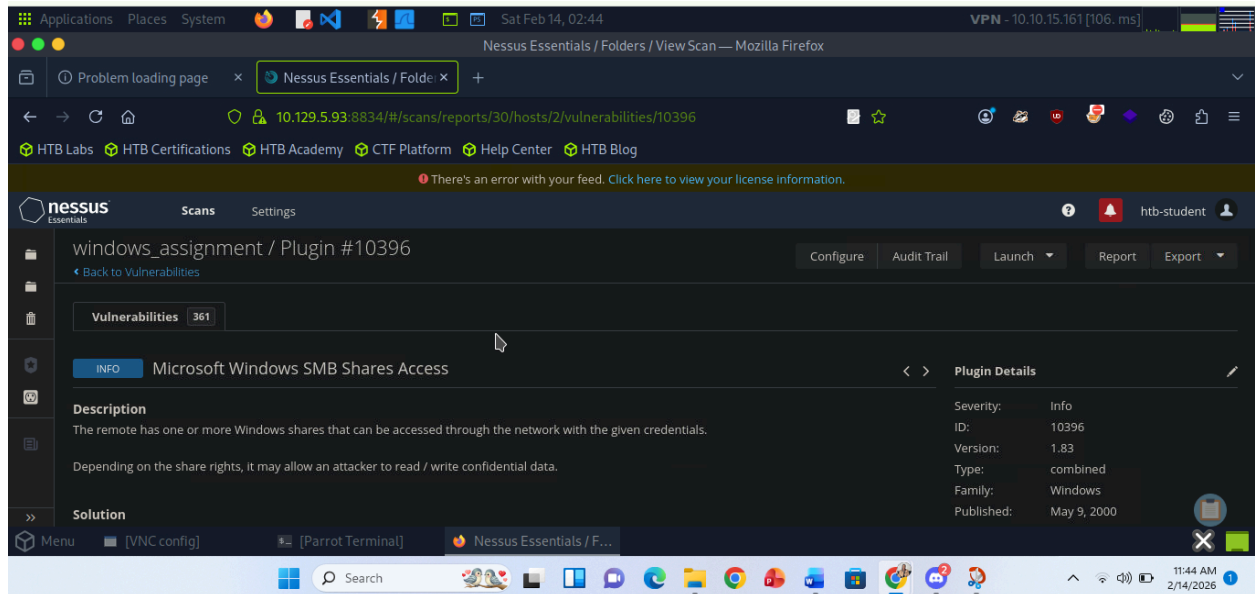
a) What is the name of one of the accessible SMB shares from the authenticated Windows scan?

Answer: wsus

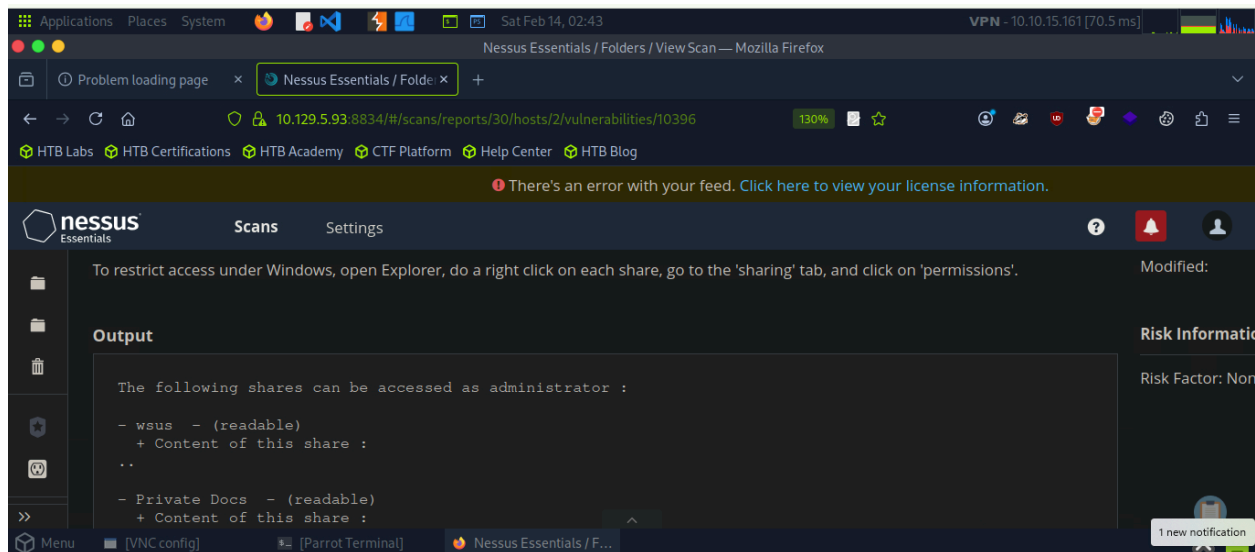


Explanation:

In the search button I pasted SMB shares directly and got the below results from the screenshot shown below. In the information provided it shows the vulnerability description, recommendation solutions and output.

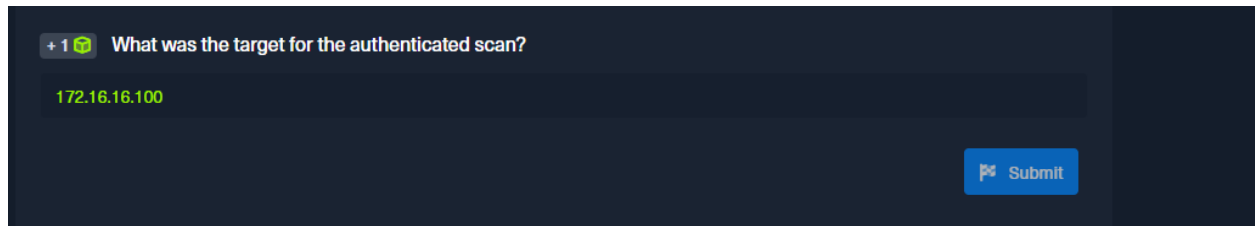


In the screenshot below , we can clearly read the name as wsus.

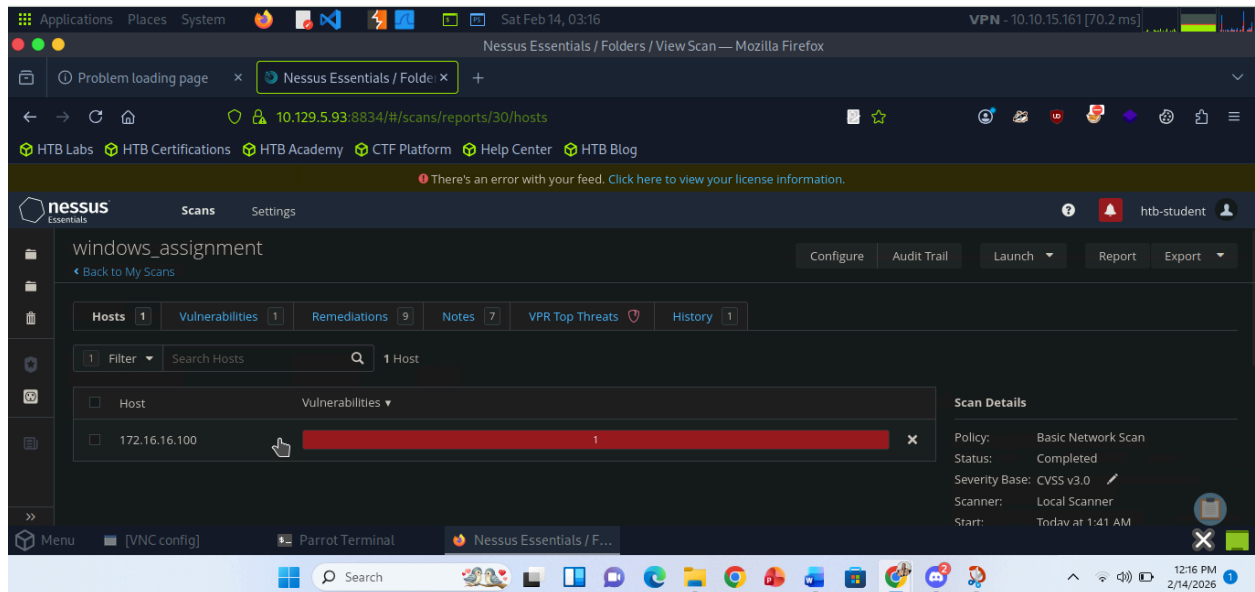


b) What was the target for the authenticated scan?

Answer: 172.16.16.100

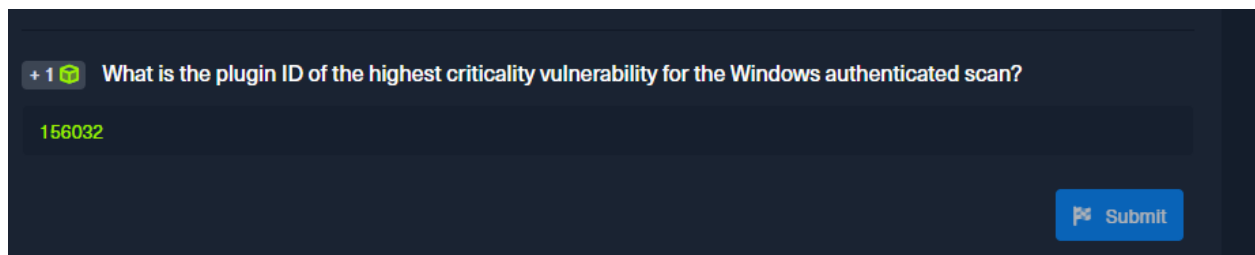


From the screenshot below, the host is clearly :172.16.16.100



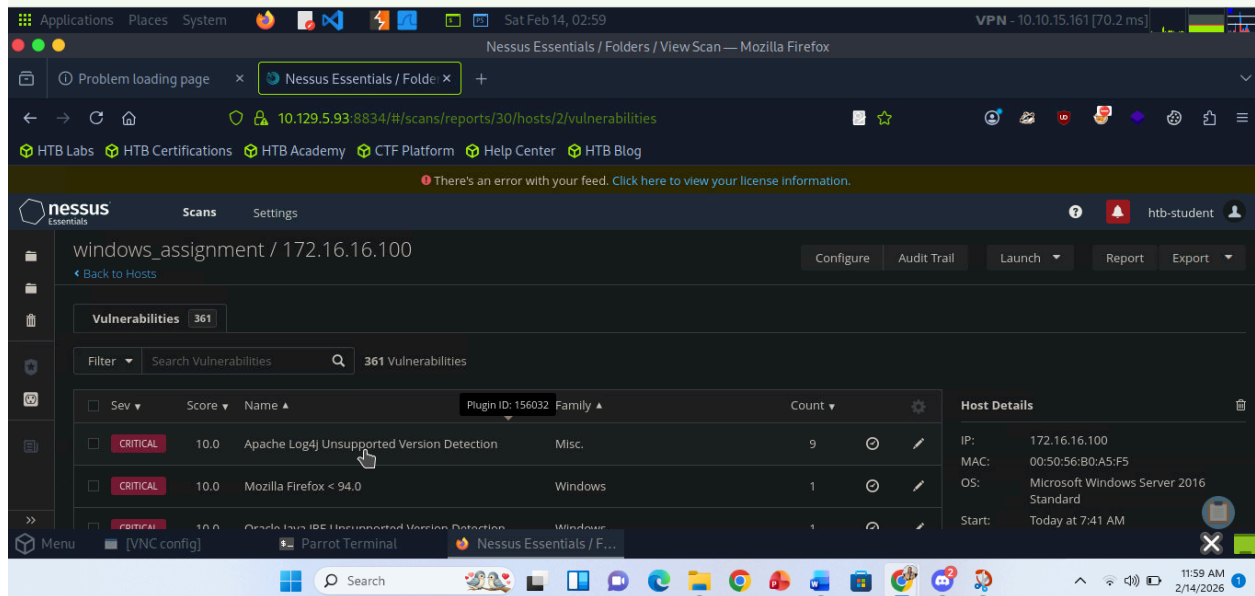
c)What is the plugin ID of the highest criticality vulnerability for the Windows authenticated scan?

Answer: 156032



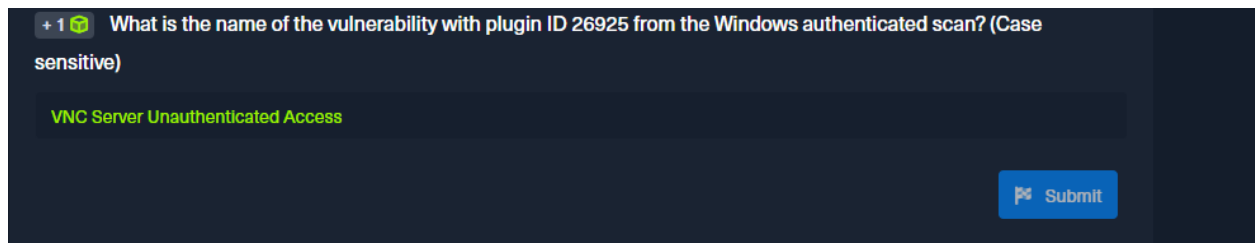
Explanation.

From the screenshot below , it displays the vulnerability with the most critical metrics. I hovered over the vulnerability and the plugin ID is displayed as 156032.



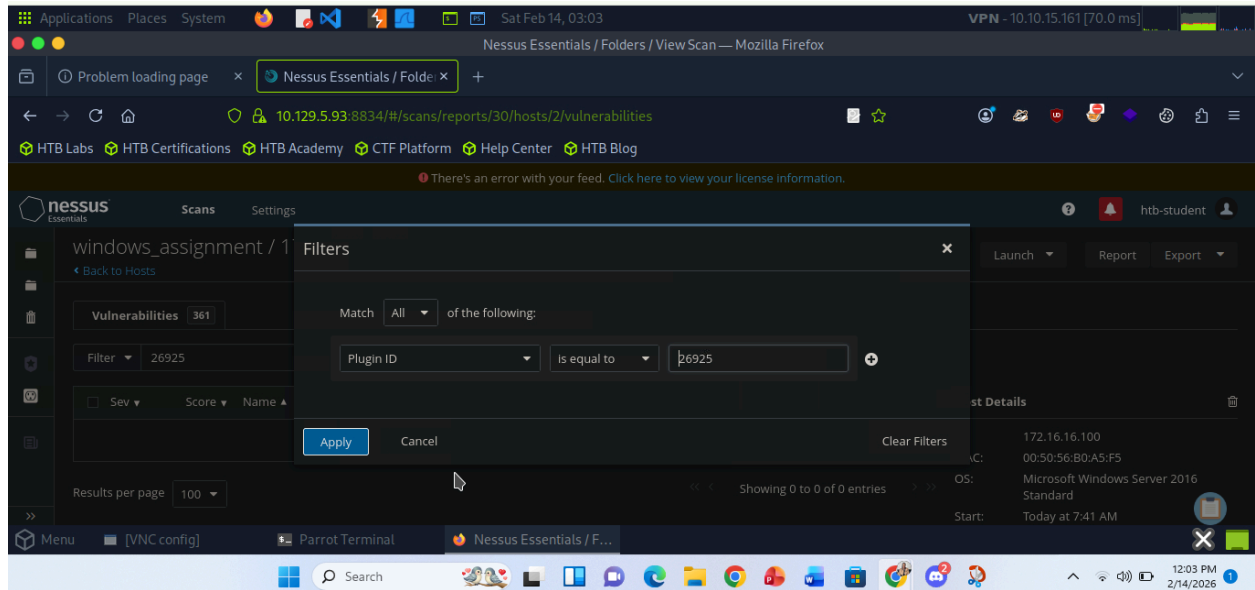
d)What is the name of the vulnerability with plugin ID 26925 from the Windows authenticated scan?

Answer: VNC Server Unauthenticated Access

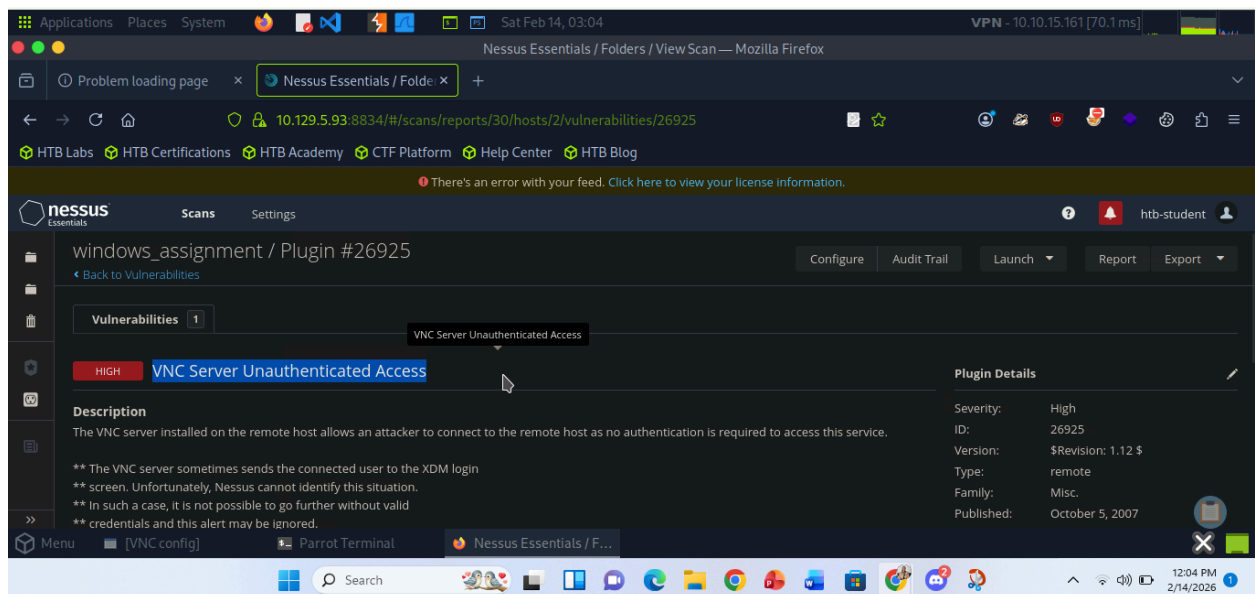


Explanation:

In the search bar, alongside it there is a filter icon. I navigated through the file options and got to the plugin ID, the operator i chose is equal to comparison. I then pasted my ID 26925 in the space button and applied the filter. As shown below.



The vulnerability with the plugin ID 26925 is VCN Server Unauthenticated Access. This was obtained after I applied the filter.



e) What port is the VNC server running on in the authenticated Windows scan?
 Answer: 5900

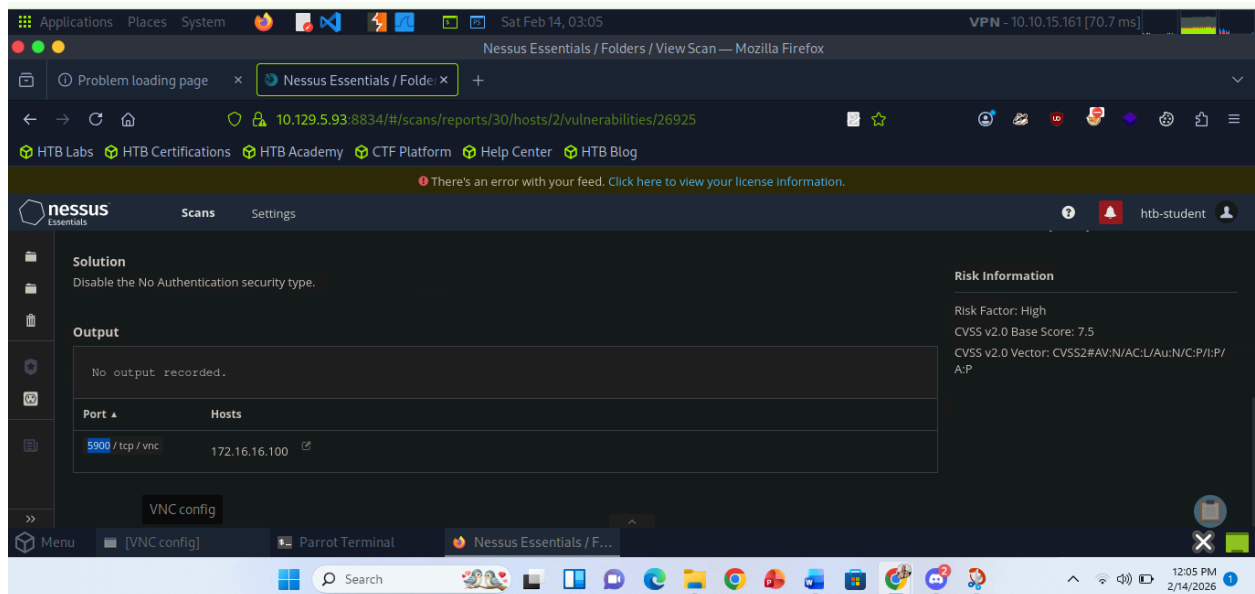
+ 1 🟢 What port is the VNC server running on in the authenticated Windows scan?

5900

Submit

Explanation:

In the previous question , I identified the vulnerability name as VCN server. In this question , I am to identify the port number. I went down to the description of the vulnerability and identified the port number as 5900.

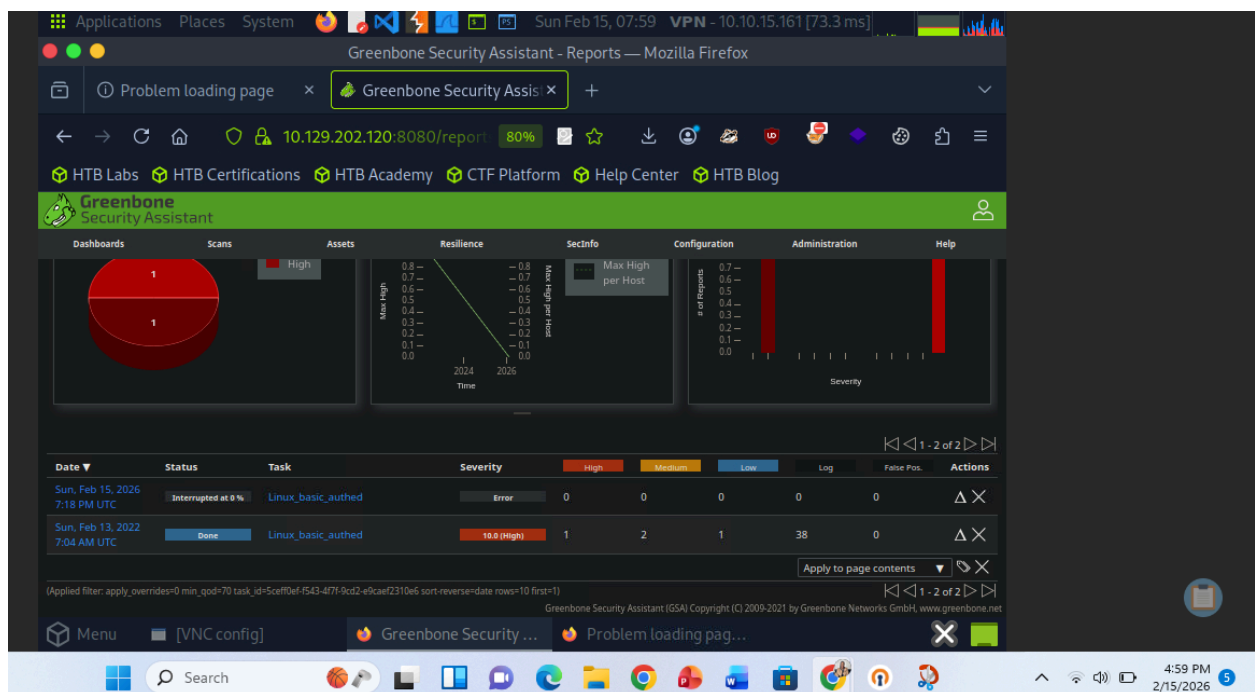
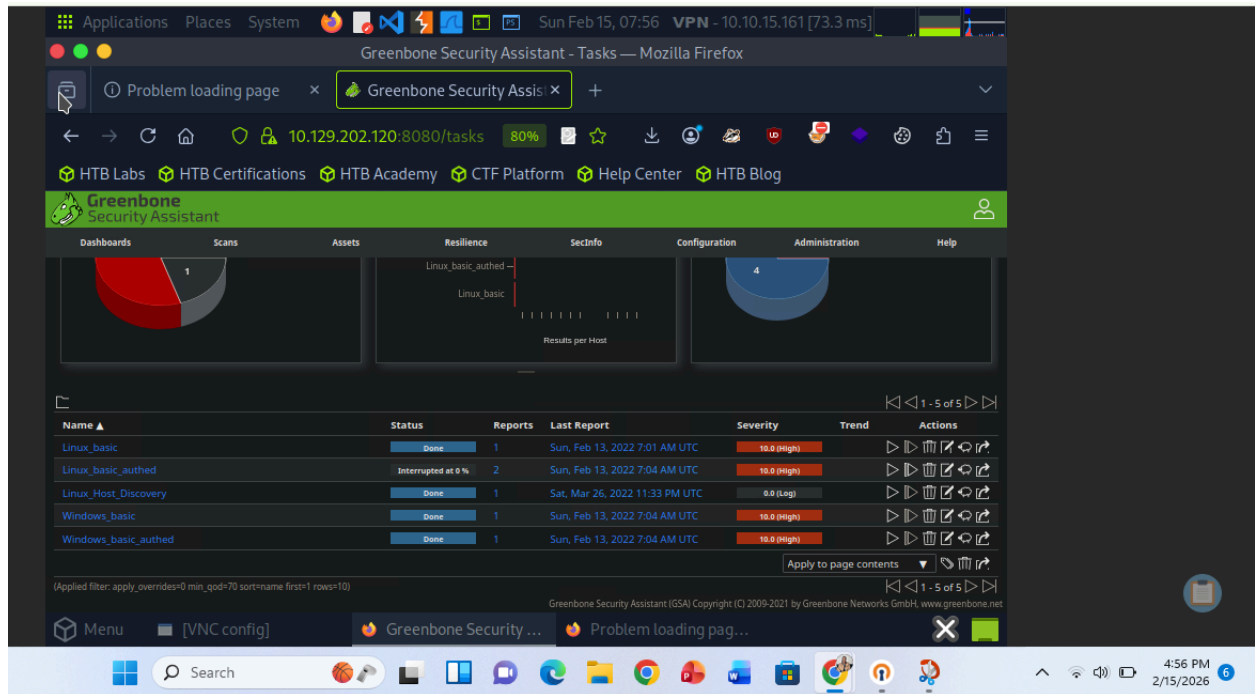


1.3 OpenVas Skill Assessment

Once logged in, create a new task with the OpenVAS Default Scanner and use the Full and Fast config against the target: 172.16.16.160. Additionally, ensure you have the scan set up to run as an authenticated user using the credentials: root:HTB_@cademy_admin!. My spawn ip address-10.129.202.120

After logging in, I tried creating a new task, with the credentials but I could not save the changes.

Since there were already tasks available, I opted to use the linux_basic_authen to answer my questions. I re-ran the scan again as shown in the screenshot below.

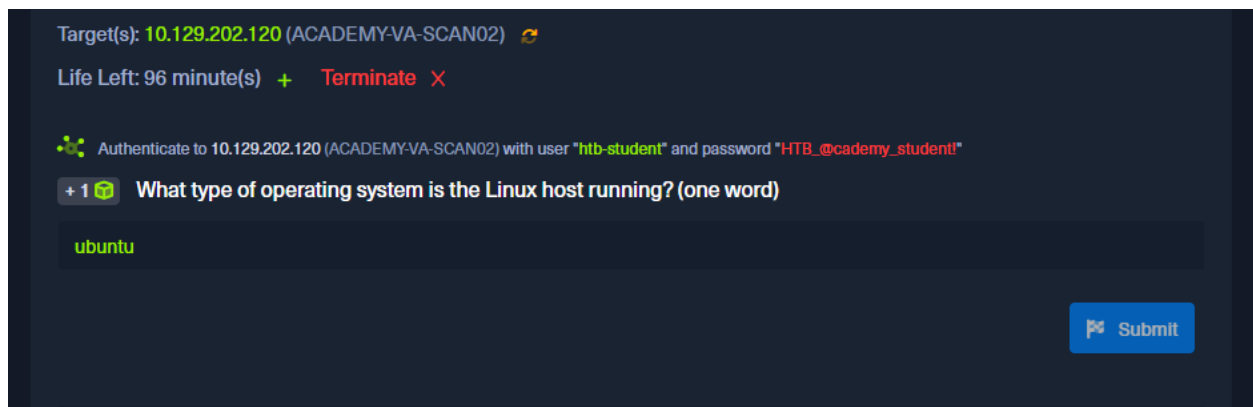


From the screenshot above, my scan was interrupted 😞. I used the one where the status was done.

Questions

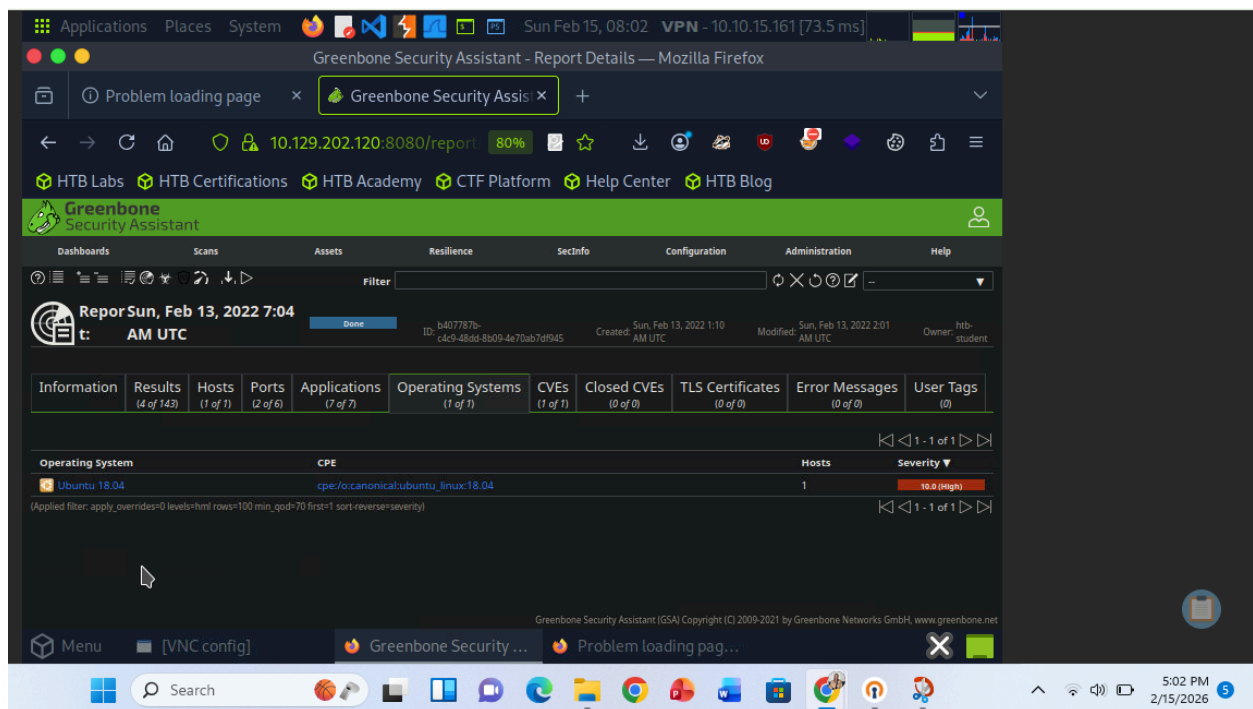
a) What type of operating system is the Linux host running? (one word)

Answer: Ubuntu



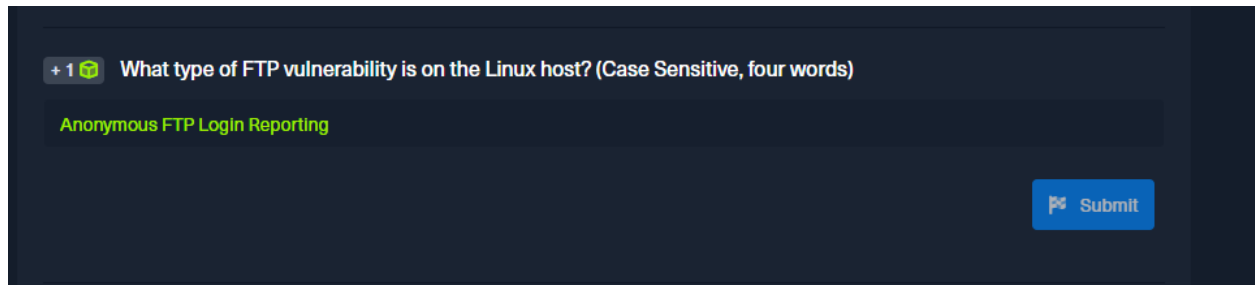
Explanation: I clicked on the task, and there was a load of information tied to the report including the Results, Hosts, Ports, Applications, Operating System, CVEs, TLS certificate and others as shown in the screenshot below.

I clicked on the operating System button and the answer is Ubuntu



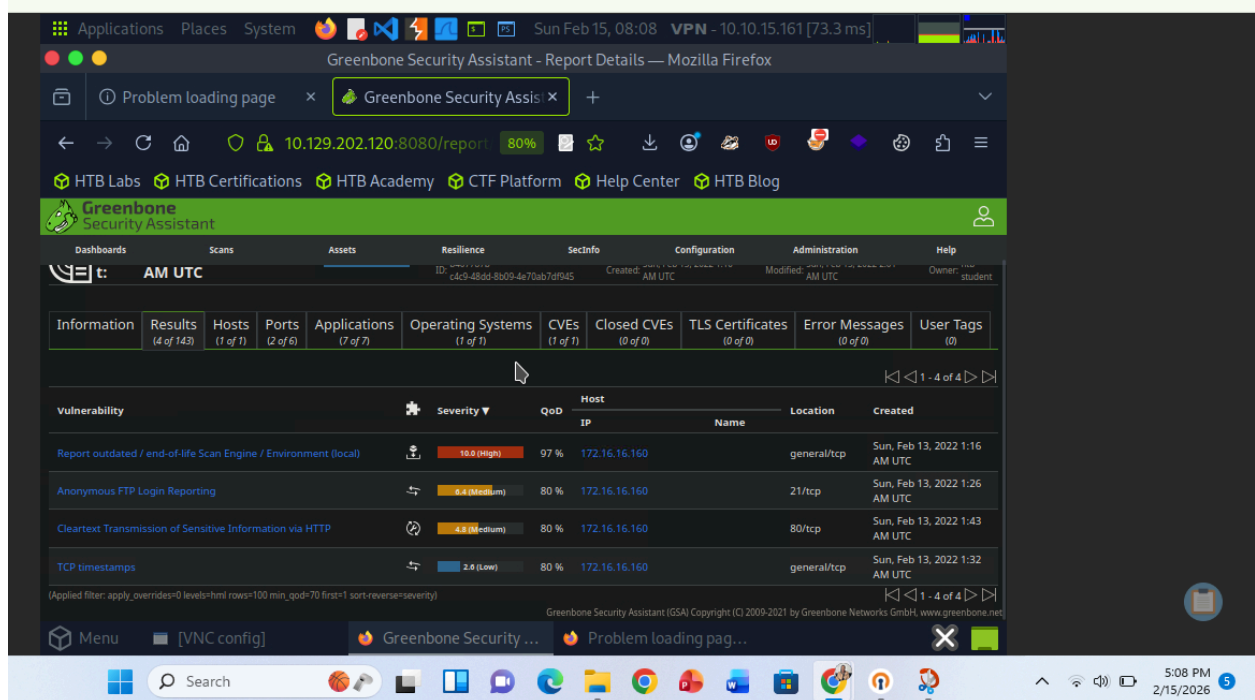
b)What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

Answer:Anonymous FTP Login Reporting



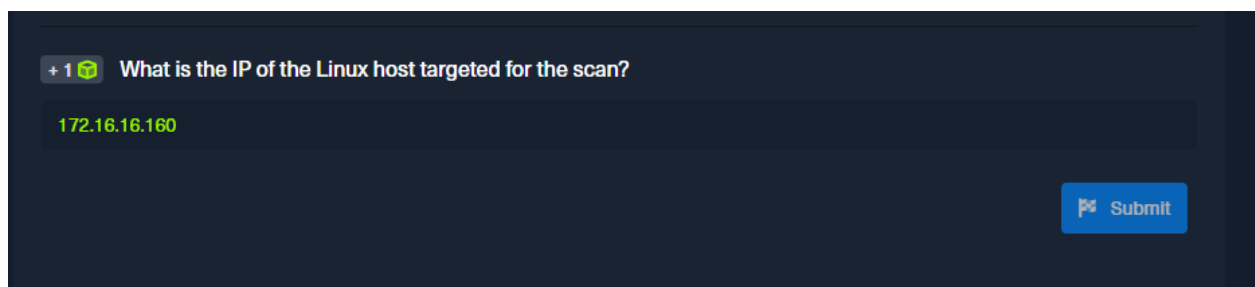
Explanation:

I got the FTP vulnerability from the result button , as shown in the screenshot below



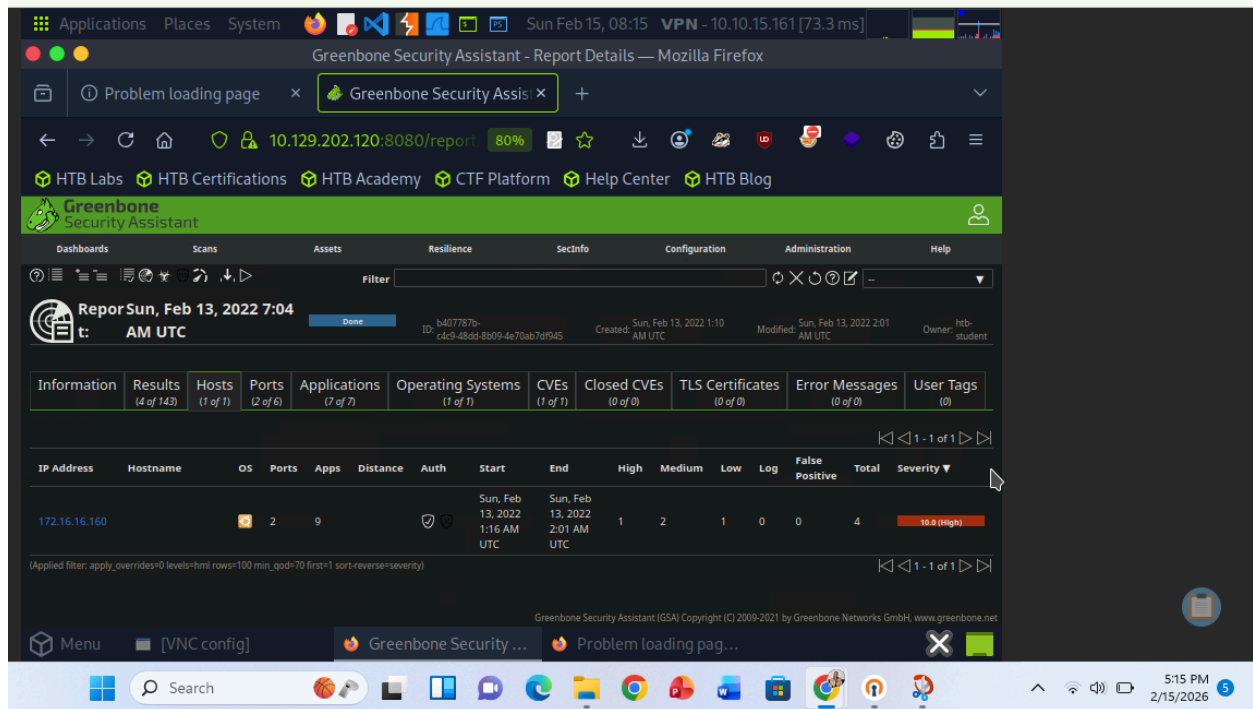
c)What is the IP of the Linux host targeted for the scan?

Answer: 172.16.16.160



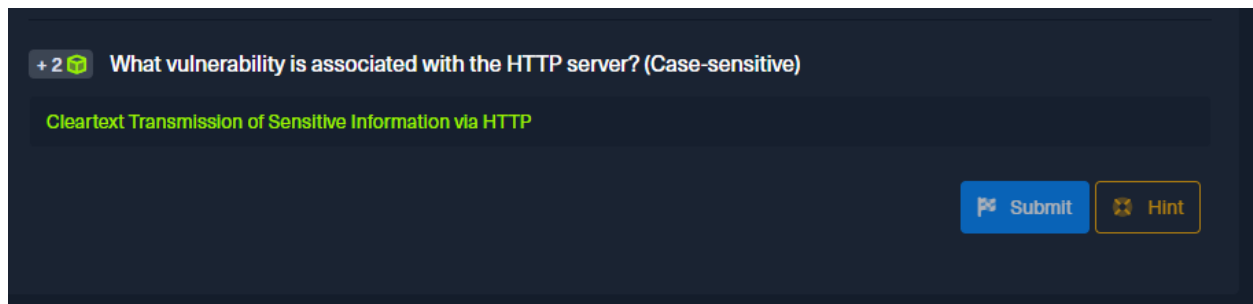
Explanation:

In this task i clicked the host button to get the IPaddress as shown in the screenshot below:



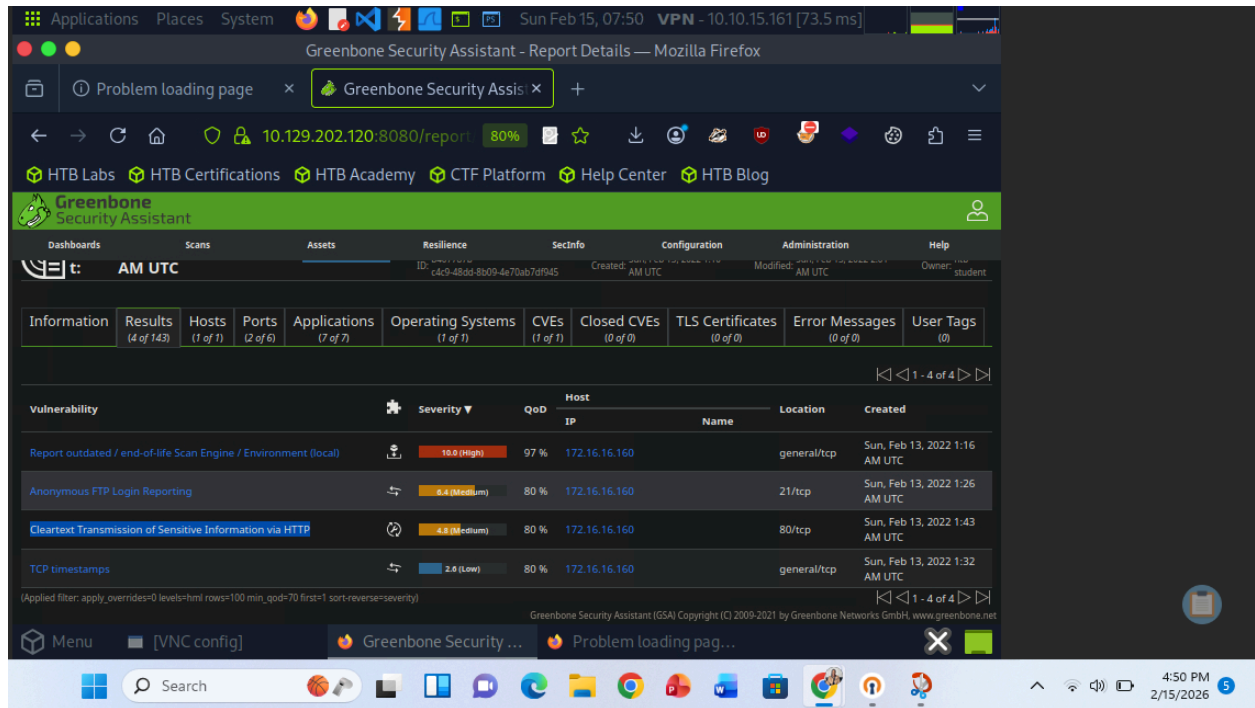
d)What vulnerability is associated with the HTTP server? (Case-sensitive)

Answer: Cleartext Transmission of Sensitive Information via HTTP



Explanation

I got the answer from the result button, the question wanted a vulnerability associated with HTTP server. The answer is Cleartext Transmission of Sensitive Information via HTTP as shown in the screenshot below.



1.4 Conclusion and summary

This module provided me a solid foundation in vulnerability scanning and penetration testing by combining both technical skills and compliance awareness. Through hands-on experience with Nessus and OpenVAS, I gained practical knowledge on installing, configuring, and executing scans effectively within virtual environments. The module also reinforces the importance of following best practices and adhering to compliance standards to ensure that assessments are conducted ethically and professionally.

Overall, I not only learnt how to identify and analyze vulnerabilities but also how to document findings clearly and present them in well-structured reports. These skills are essential for all the security analysts.

Below is a screenshot and a link to the completion of the module.

<https://academy.hackthebox.com/achievement/2382167/108>

